

CTCH 605

Introduction to Cybersecurity

Security Assessment Report

Prepared By: *Grayson Gyasi*

Table of Contents

Table of Contents.

1. Executive Summary	2
2. Assessment Scope	2
3. Assessment Methodology	5
4. Detailed Findings	6
5. Recommendations	20
6. Conclusion	21

1. Executive Summary

FICBANK requested an assessment of its ability to collect, monitor, and analyze security monitoring data within its IT infrastructure. The purpose of the assessment was to determine whether the organization had effective detective security controls in place and to identify any weaknesses in monitoring and visibility capabilities. To fulfill the business requirements, network discovery, vulnerability scanning, and security monitoring analysis were conducted using multiple web server log files, network traffic analysis and TrID file analysis. The assessment included identifying active hosts, scanning exposed services, evidence of normal web traffic, digital forensic investigation, network packet captures, vulnerability scanning attempts, HTTP POST requests, malformed requests, and a Shellshock exploitation attempt. During the assessment:

- 3 active hosts were identified through network scanning.
- 2 hosts were successfully scanned using vulnerability assessment tools thus; Nessus Essentials.
- Multiple exposed services and remote access ports were discovered.
- Several monitoring and detective control gaps were identified.
- 10 HTTP tunneling attempts detected
- A Shellshock exploitation attempt originated from IP address 61.161.130.241
- Most traffic appeared to be legitimate web traffic
- 11 malformed requests containing binary data were identified
- Several files could not be positively identified using TrID
- Potential attempts to upload unauthorized files to the web application
- Multiple evidence sources identified suspicious communications involving external systems

Based on these findings, a technical security control plan was developed to strengthen FICBANK's security posture. The recommended controls include perimeter security enhancements, network segmentation, stronger identity and access management, endpoint protection, centralized monitoring, vulnerability management, and secure backup and recovery processes.

2. Assessment Scope

The assessment focused on evaluating the security monitoring and logs, security events and incident response of FICBANK's internal network infrastructure.

Systems and Network Assessed

- Windows-based systems
- Kali Linux assessment workstation

- Internal network range: 10.15.4.1/24
- Web server access logs (access-1.log)
- Apache web server logs (apache_logs)
- Web server access logs (access-2.log)
- CTCH605Project3Wireshark.pcap packet capture

Number of Systems Identified

- 3 active hosts discovered through Nmap scanning
- 2 hosts fully identified and scanned using Nessus Essentials
- Three web server log files analyzed
- 1,753 unique IP addresses identified in the Apache log file
- 48 unique IP addresses identified in the access-2 log file
- Several systems involved in HTTP communications observed in the packet capture
- 1 external host (2.56.57.108) identified in the packet capture communicating with the web application.

Tools, Techniques, and Practices Employed

Nmap	Host discovery and port scanning
Nessus Essentials	Vulnerability scanning and assessment
Windows Command Prompt	ipconfig to identify IP address and subnet identification
grep	Log searching and pattern matching
MATE Terminal	Linux command-line interface
awk	Log parsing and field extraction
sort	Data organization
wc	Counting entries
uniq	Identifying unique values
Wireshark	Analyze the packet capture (PCAP)
TrID	Used to determine the true file types

Predictions

Prior to testing, it was predicted that:

- Multiple hosts would be active on the network.
- Remote access services such as RDP and SSH would be exposed.
- The organization would lack centralized monitoring capabilities.
- Vulnerability scanning would identify several exposed services and potential risks.
- I expected the log files to contain source IP addresses, timestamps, requested web resources and HTTP methods.
- I expected to see evidence of both legitimate user activity and potentially suspicious activities.
- Unauthorized access attempts and malware-related artifacts
- Unusual network traffic and suspicious file transfers

Results

The assessment confirmed:

- 3 active hosts on the network.
- Multiple exposed services including SSH, RDP, SMB, and WinRM.
- Limited evidence of centralized logging or SIEM monitoring.
- Several services increased the organization's attack surface.
- Web server logs successfully captured security-relevant events.
- Multiple indicators of reconnaissance and exploitation activity were identified.
- Security monitoring data provided visibility into HTTP methods, user agents, status codes, and attack attempts.
- Communications observed with external host 2.56.57.108
- Several suspicious JPG files and main.php transferred through HTTP sessions
- TrID classified multiple files as Unknown file types
- Correlation between Wireshark, TrID, and log analysis increased confidence in the findings

- Most active IP address: 80.82.70.243 and Suspicious POST request identified from 95.213.177.126

3. Assessment Methodology

The methodology followed a structured vulnerability assessment, detective control evaluation process, network traffic and TrID analysis consistent with common cybersecurity industry standards such as National Institute of Standards and Technology Cybersecurity Framework and Vulnerability Management best practices

Step 1 – Network Identification

The Windows host IP address and subnet were identified using the ipconfig command. The network range was converted into CIDR notation for scanning purposes.

Step 2 – Host Discovery

A network discovery scan was conducted using Nmap to identify active hosts and accessible services on the internal network.

Step 3 – Vulnerability Assessment

Nessus Essentials was used to perform vulnerability discovery and host analysis on identified systems.

Step 4 – Service Enumeration

Open ports and exposed services were analyzed to determine potential security monitoring requirements and attack surface exposure.

Step 5 - Nessus Vulnerability Scan

Nessus Essentials tool was used to scan the two active hosts to determine the known vulnerabilities

Step 6 - Security Monitoring Data Collection

Three web server log files were collected and reviewed to evaluate FICBANK's ability to collect and retain security monitoring data. The logs contained source IP addresses, timestamps, HTTP methods, status codes, requested resources, and user-agent information.

Step 7 - Log Analysis

Linux command-line utilities including grep, awk, sort, uniq, and wc were used to search, filter, count, and analyze log entries. Queries were performed to identify patterns, anomalies, browser activity, HTTP methods, attack attempts, and indicators of compromise.

Step 8 - Security Event Analysis

Security-relevant events were reviewed to determine evidence of reconnaissance activity, vulnerability scanning, exploitation attempts, malformed requests, and abnormal web traffic patterns.

Step 9 - Wireshark Packet Capture Analysis

Wireshark was used to analyze the provided packet capture (PCAP) file to identify suspicious network activity and potential Indicators of Compromise (IoCs). HTTP traffic was filtered and reviewed to examine communications between systems, identify file transfers, and reconstruct HTTP streams. Exported HTTP objects were analyzed to determine what files were transferred across the network and whether any suspicious or unauthorized activity had occurred.

Step 10 - TrID File Identification Analysis

TrID File Identifier was used to determine the true file types of files reconstructed from the packet capture. Several files, including multiple .jpg files and a file named main.php, were analyzed against TrID's file signature database to verify whether their content matched their file extensions

Step 11 - Incident Correlation and Indicators of Compromise

Evidence obtained from Wireshark packet analysis, TrID file identification, and web server log analysis was correlated to identify relationships between suspicious network activity, file transfers, and web application events. By comparing findings across multiple data sources, it was possible to validate observations and build a clearer picture of the potential attack.

4. Detailed Findings

Finding 1: Network Identification

Action: I opened Windows Command Prompt and executed: ipconfig

Result The system returned the following IPv4 address:

- 10.15.4.149
- Subnet used for assessment: 10.15.4.1/24



Finding 2: Host Discovery Scan

Action: I executed the following Nmap scan from Kali Linux: `sudo nmap 10.15.4.1/24` **Result:** Nmap successfully identified: 3 active hosts and multiple exposed TCP services

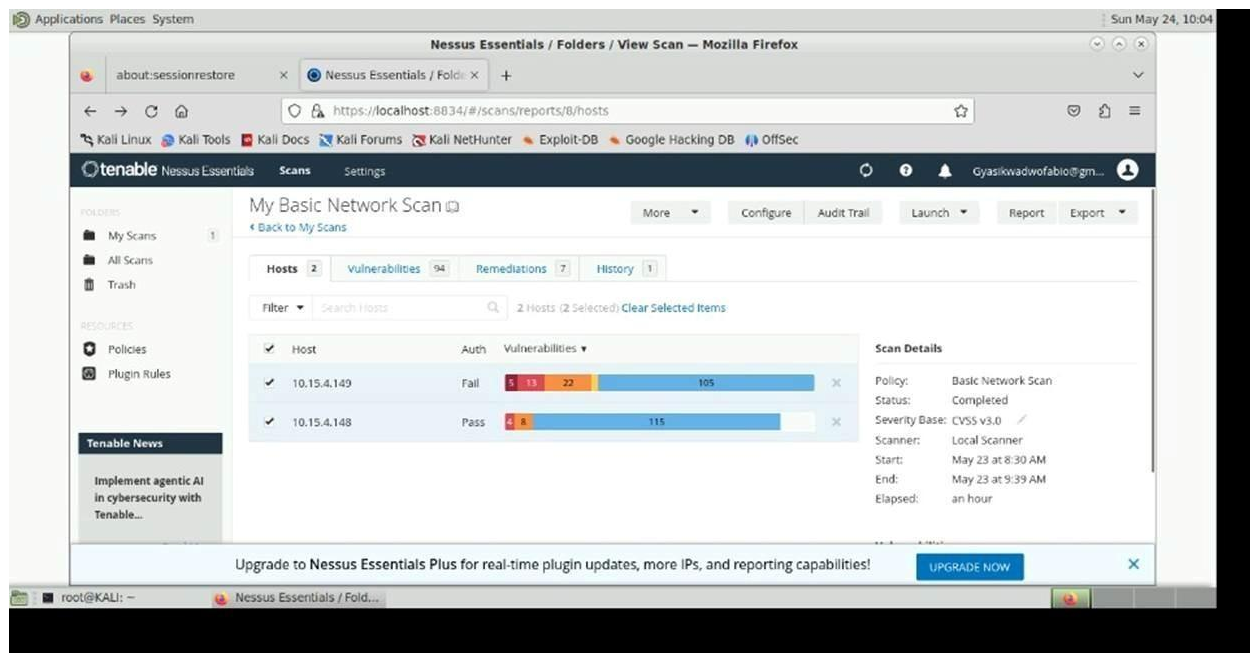
Open services included:

- SSH (22)
- MSRPC (135)
- NetBIOS (139)
- SMB (445)
- RDP (3389)

Finding 3: Nessus Host Discovery/ Vulnerability Assessment

Action: I configured and executed a Nessus Host Discovery Scan against 10.15.4.1/24

Result: Host 10.15.4.148 and 10.15.4.149. These hosts were selected for vulnerability scanning.

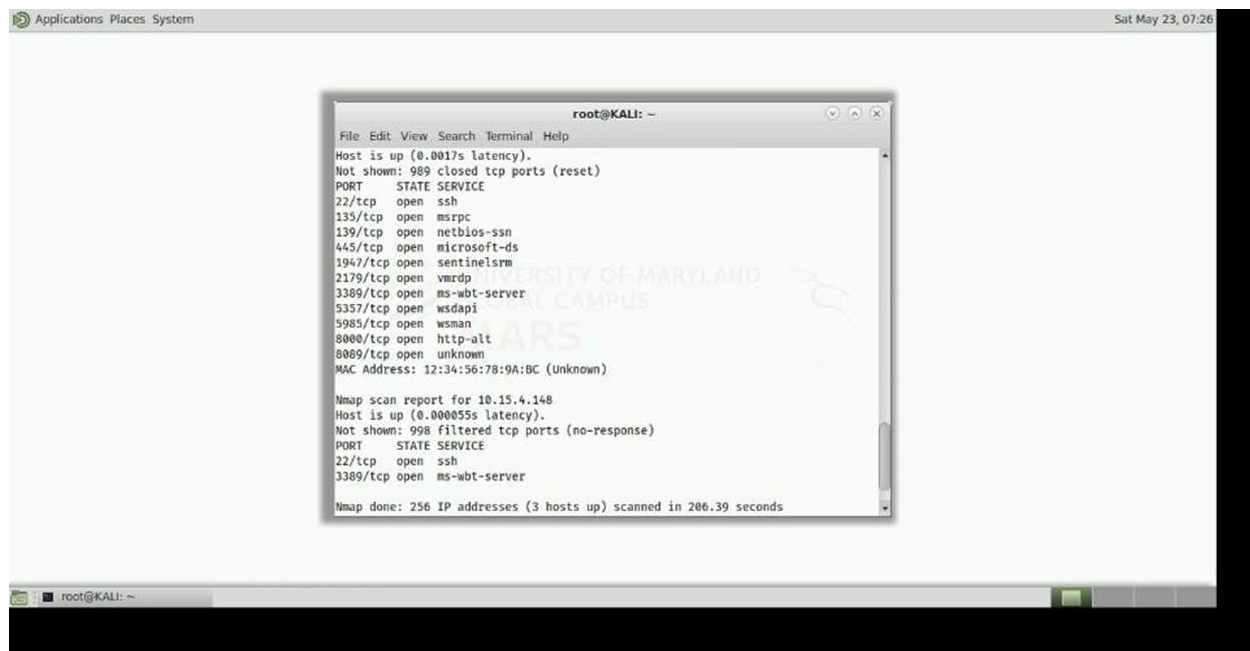


Finding 4 – Service Enumeration and Analysis

Action: Reviewed identified services and analyzed potential monitoring concerns.

Result: The following security concerns were identified:

Port	Service	Potential Risk
Port 22	SSH	Unauthorized remote access
Port 445	Microsoft-ds	Lateral movement and SMB exploitation
Port 3389	RDP	Brute-force and ransomware targeting
Port 5985	WinRM	Remote management exposure
Port 8000	HTTP-ALT	Potential web application exposure



Finding 5: Nessus Vulnerability Scan Results

Action: I executed a Basic Network Scan in Nessus Essentials against the identified hosts:

- 10.15.4.148
- 10.15.4.149

The scan was configured using the Basic Network Scan policy and ran through the local Nessus scanner.

Result: The vulnerability scan successfully identified multiple vulnerabilities across both hosts.

Host: 10.15.4.149; Authentication Status

- Failed Authentication Vulnerability Summary:
- 5 Critical Vulnerabilities
- 13 High Vulnerabilities
- 22 Medium Vulnerabilities
- 105 Informational Findings

Host: 10.15.4.148; Authentication Status:

- Successful Authentication

Vulnerability Summary:

- 4 Critical Vulnerabilities
- 8 High Vulnerabilities
- 115 Informational Findings

Analysis

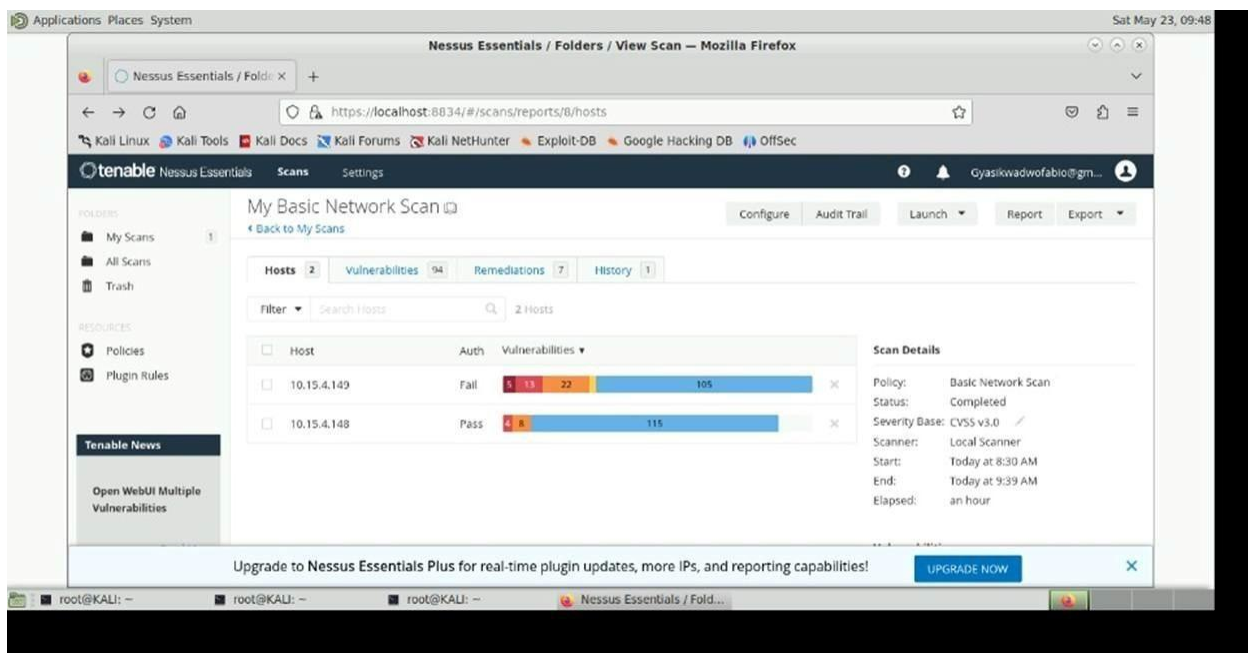
The scan results indicate that both hosts contain several high-risk vulnerabilities and exposed services that could potentially be exploited by attackers.

The failed authentication status on host 10.15.4.149 suggests Nessus may have limited access to perform credentialed scanning, potentially reducing vulnerability visibility and scan depth.

The large number of informational findings suggests that systems are exposing a significant amount of system and service information that attackers could use for reconnaissance purposes.

The identified critical and high vulnerabilities indicate that:

- Patch management may be incomplete
- Legacy or insecure services may still be enabled
- Remote access services increase attack surface exposure
- Continuous monitoring and remediation are necessary



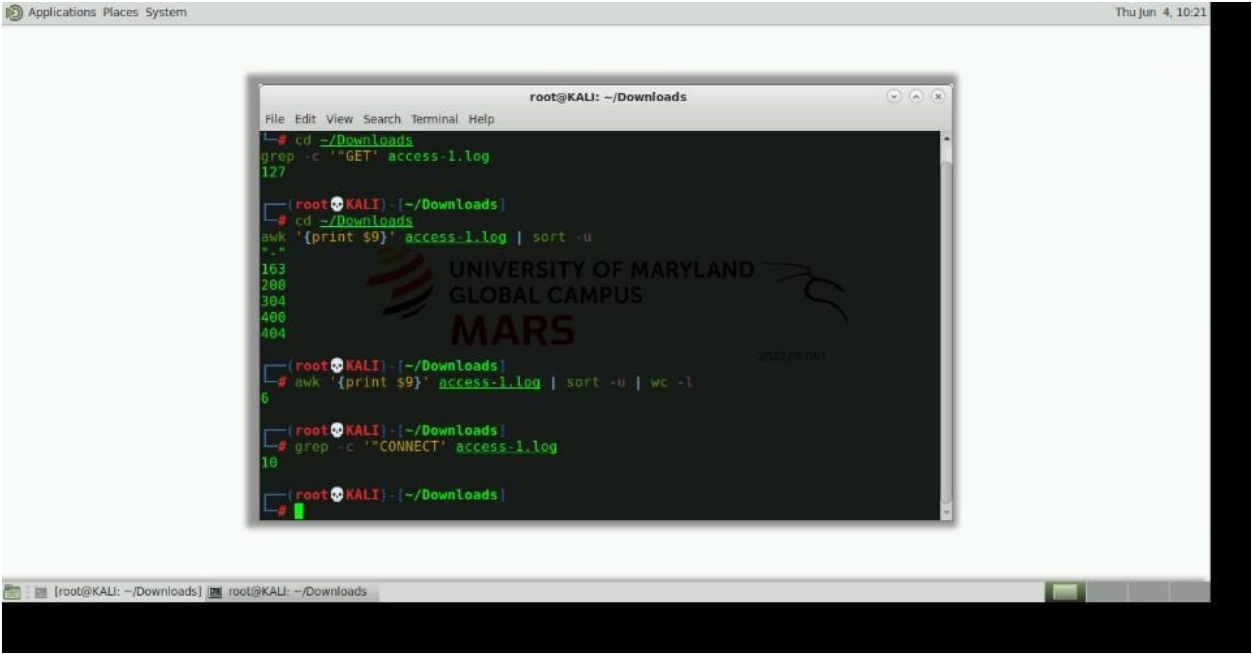
Finding 6: Access-1 Log Analysis

Action: I reviewed the access-1 web server log file using grep, awk, and related Linux command-line tools.

Result: I identified 127 GET requests, 10 HTTP CONNECT requests, 11 malformed requests containing binary data, 55 unique user agents, 11 Firefox requests, 2 attempts targeting CVE2020-8515

Analysis

The HTTP CONNECT requests indicate tunneling activity. The malformed requests suggest service identification, scanning, or protocol misuse. The CVE-2020-8515 requests indicate attackers were actively probing for vulnerable devices.



The screenshot shows a Kali Linux desktop environment with a terminal window open. The terminal displays the following commands and output:

```
root@KALI: ~/Downloads
File Edit View Search Terminal Help
root@KALI: ~/Downloads
# cd ~/Downloads
grep -c '"GET"' access-1.log
127

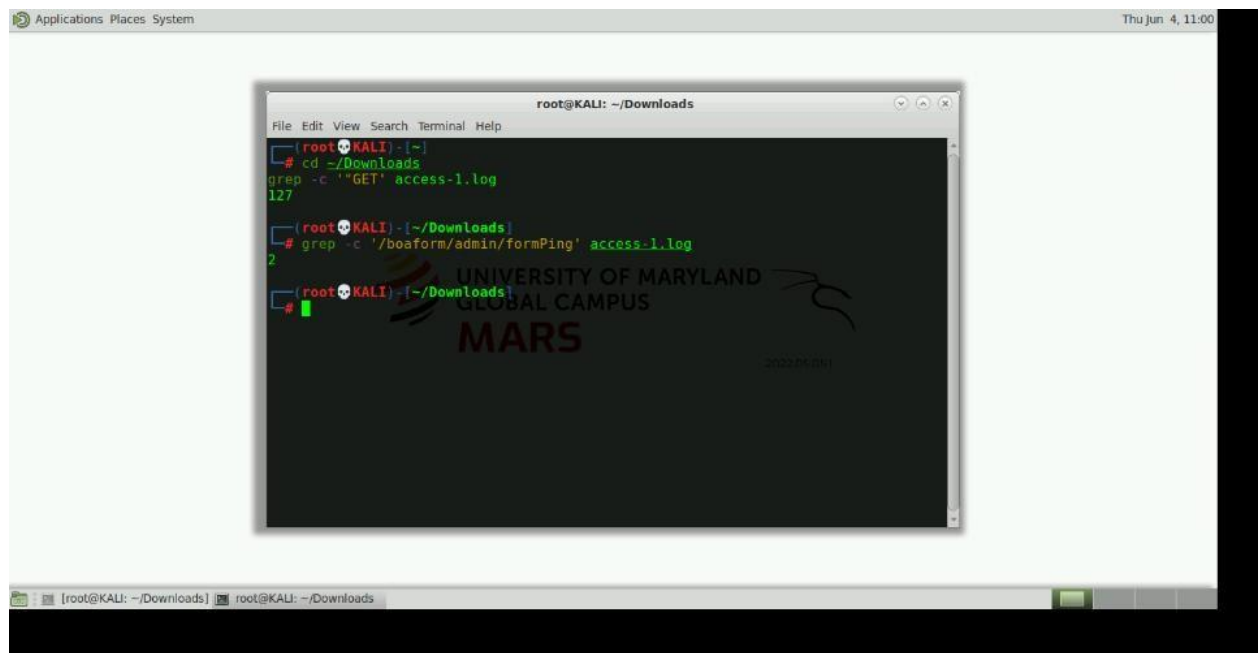
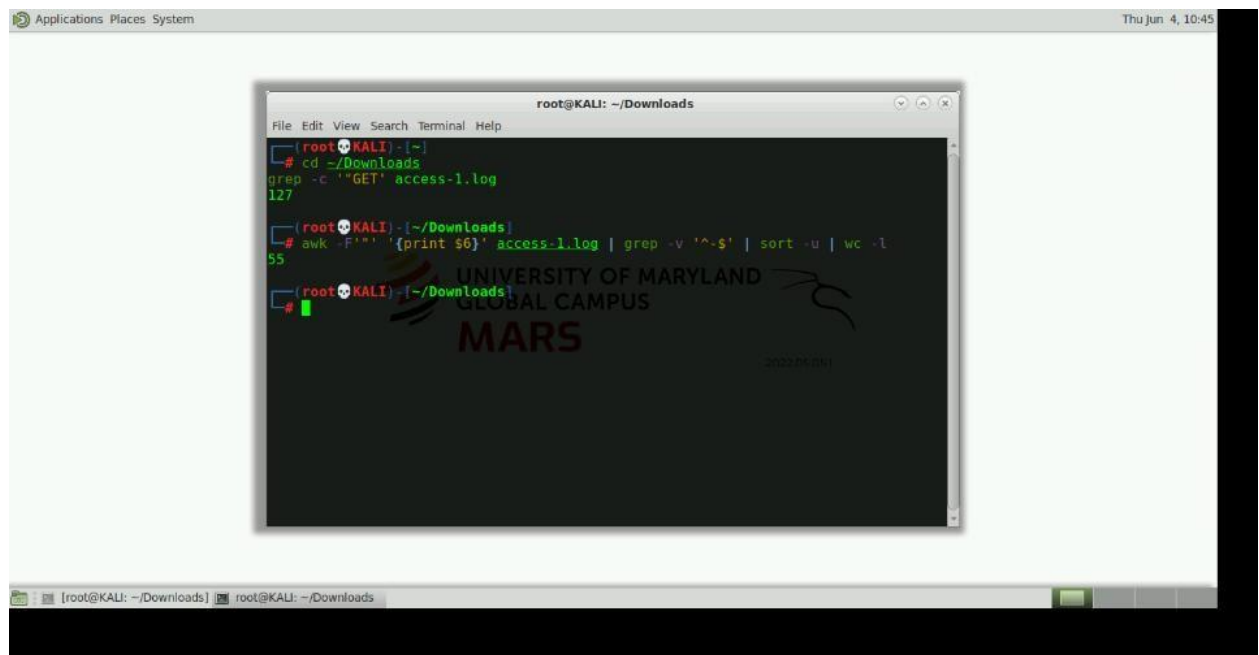
(root@KALI) - [~/Downloads]
# cd ~/Downloads
awk '{print $9}' access-1.log | sort -u
163
200
304
400
404

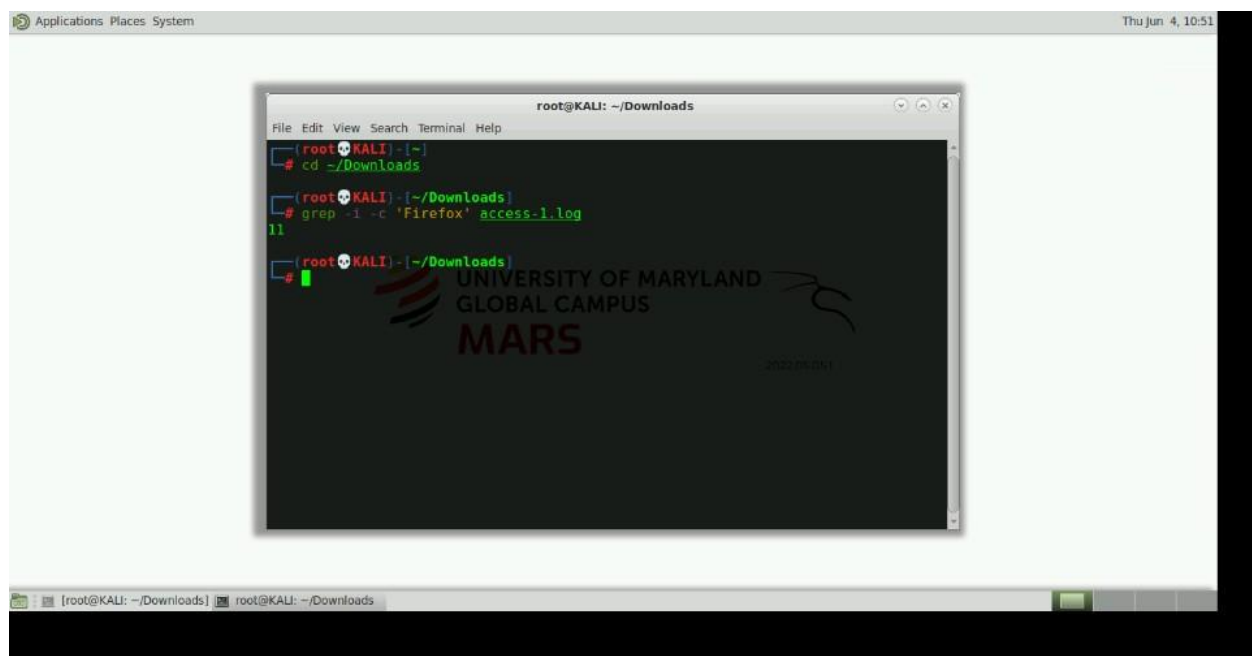
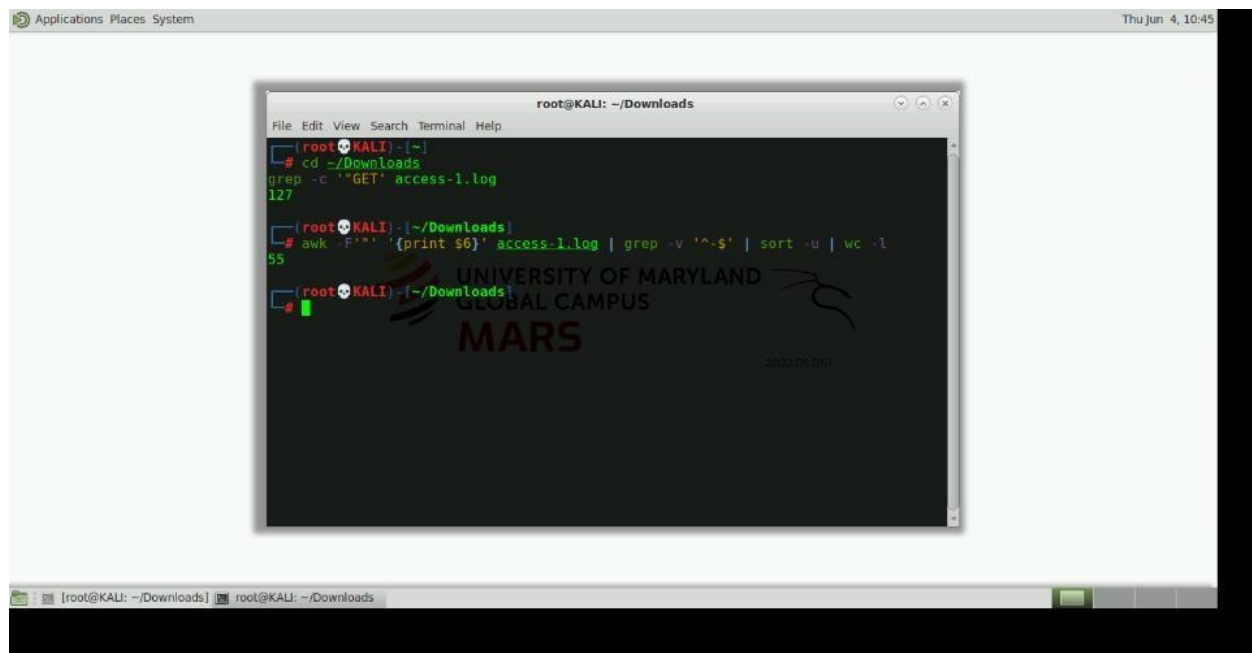
(root@KALI) - [~/Downloads]
# awk '{print $9}' access-1.log | sort -u | wc -l
6

(root@KALI) - [~/Downloads]
# grep -c '"CONNECT"' access-1.log
10

(root@KALI) - [~/Downloads]
```

The terminal window has a watermark for the University of Maryland Global Campus MARS program.



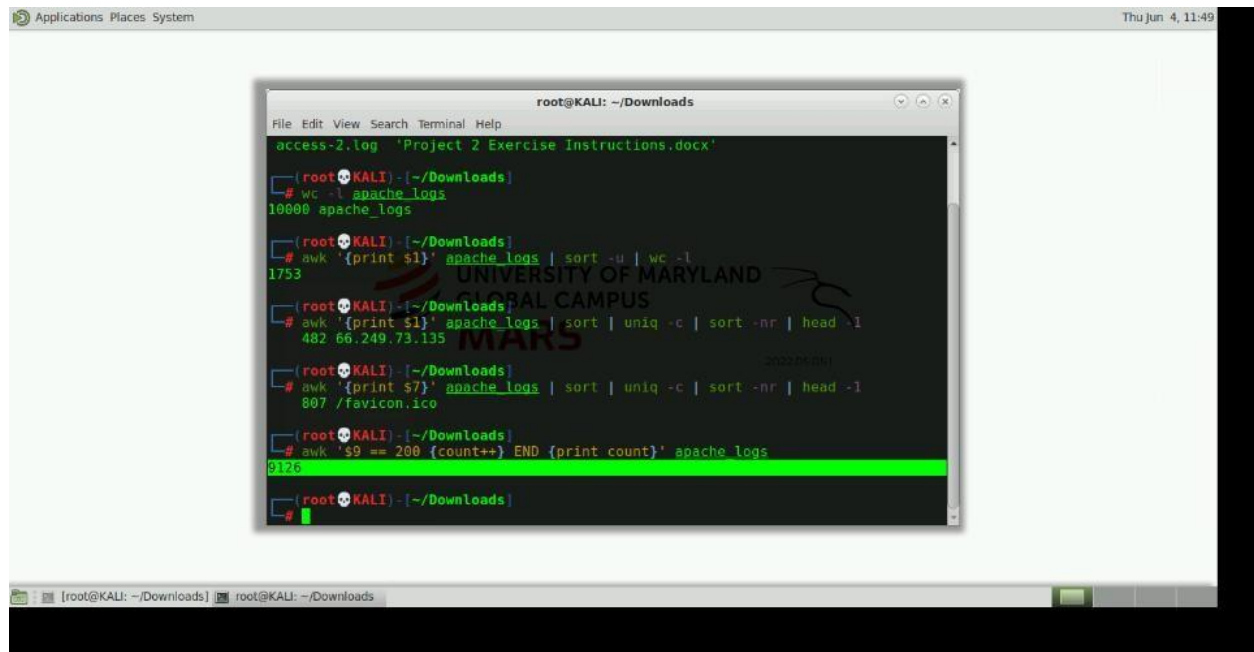


Finding 7 – Apache Log Analysis

Action: I reviewed the Apache log file to identify traffic trends and user activity.

Result: I identified 10,000 total log entries, 1,753 unique IP addresses, most active IP: 66.249.73.135, most requested resource: /favicon.ico and 9,126 HTTP 200 responses

Analysis: The large volume of successful requests suggests normal web activity. Significant traffic from search engine crawlers and automated systems was observed.



The screenshot shows a terminal window titled 'root@KALI: ~/Downloads'. The user has opened a file named 'access-2.log' which contains 'Project 2 Exercise Instructions.docx'. The terminal shows the following commands and output:

```
root@KALI: ~/Downloads
# wc -l apache_logs
10000 apache_logs

root@KALI: ~/Downloads
# awk '{print $1}' apache_logs | sort -u | wc -l
1753

root@KALI: ~/Downloads
# awk '{print $1}' apache_logs | sort | uniq -c | sort -nr | head -1
482 66.249.73.135

root@KALI: ~/Downloads
# awk '{print $7}' apache_logs | sort | uniq -c | sort -nr | head -1
807 /favicon.ico

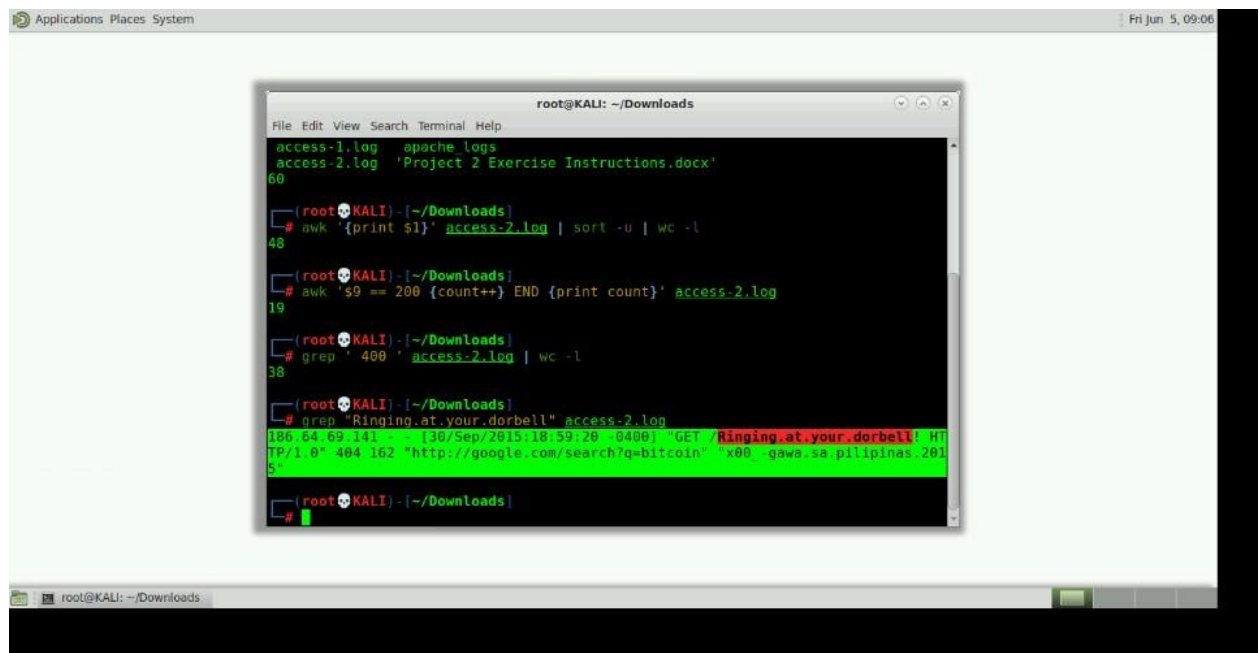
root@KALI: ~/Downloads
# awk 's9 == 200 {count++} END {print count}' apache_logs
8126
```

Finding 8 – Access-2 Log Analysis

Action: I reviewed access-2 log files for suspicious activity and indicators of compromise.

Result: I identified 60 GET requests, 48 unique IP addresses, 19 HTTP 200 responses, 38 HTTP 400 responses, Googlebot version 2.1 identified, Firefox 31.0 was most common browser version, Shellshock attempt from 61.161.130.241 and Ringing at your doorbell request from 186.64.69.141

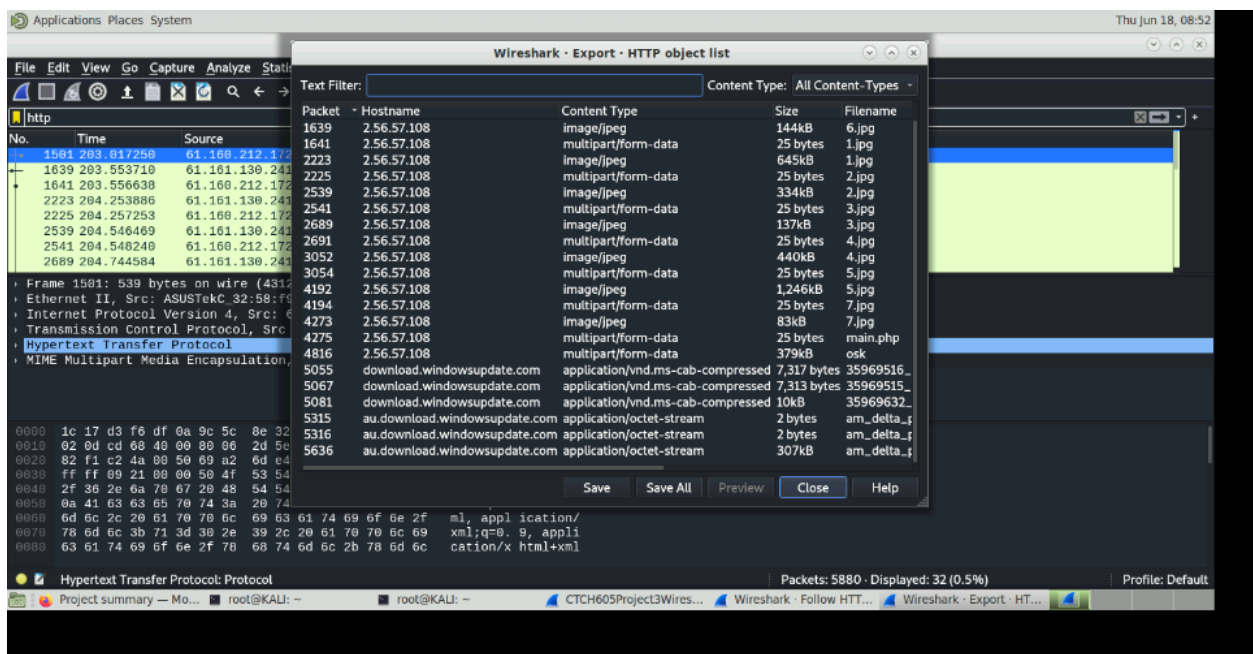
Analysis: The Shellshock attempt demonstrates active exploitation efforts against the web server. The large number of HTTP 400 responses suggests scanning or malformed requests. Googlebot activity represented normal crawler traffic.

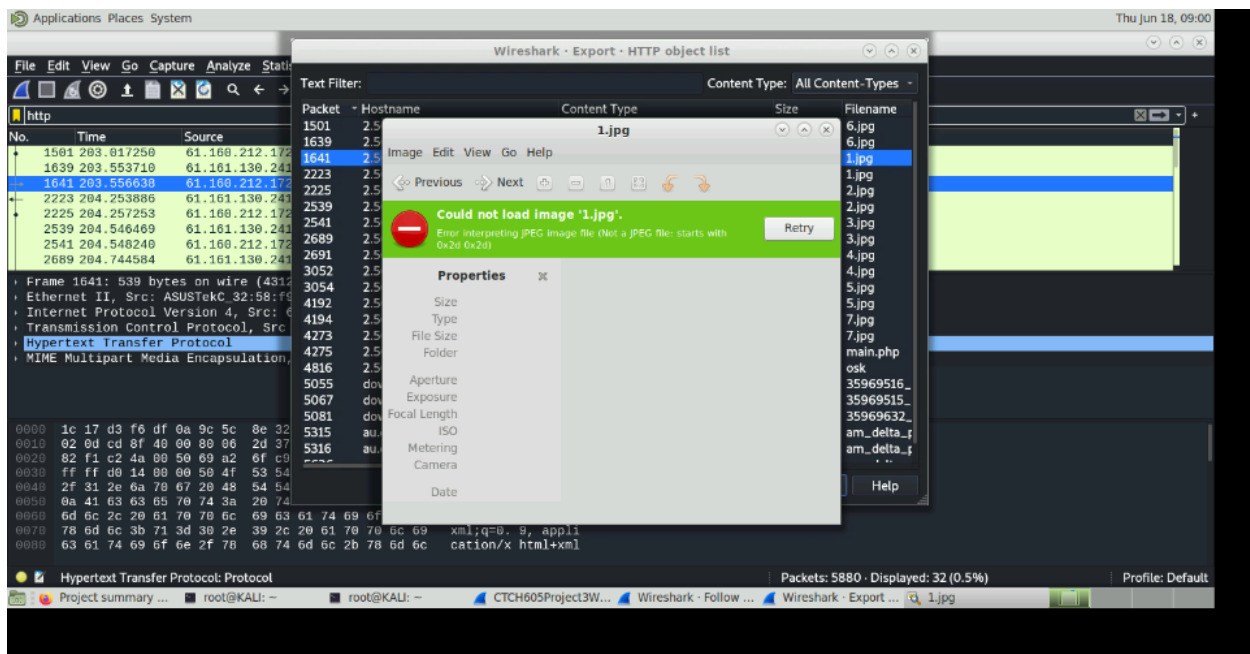
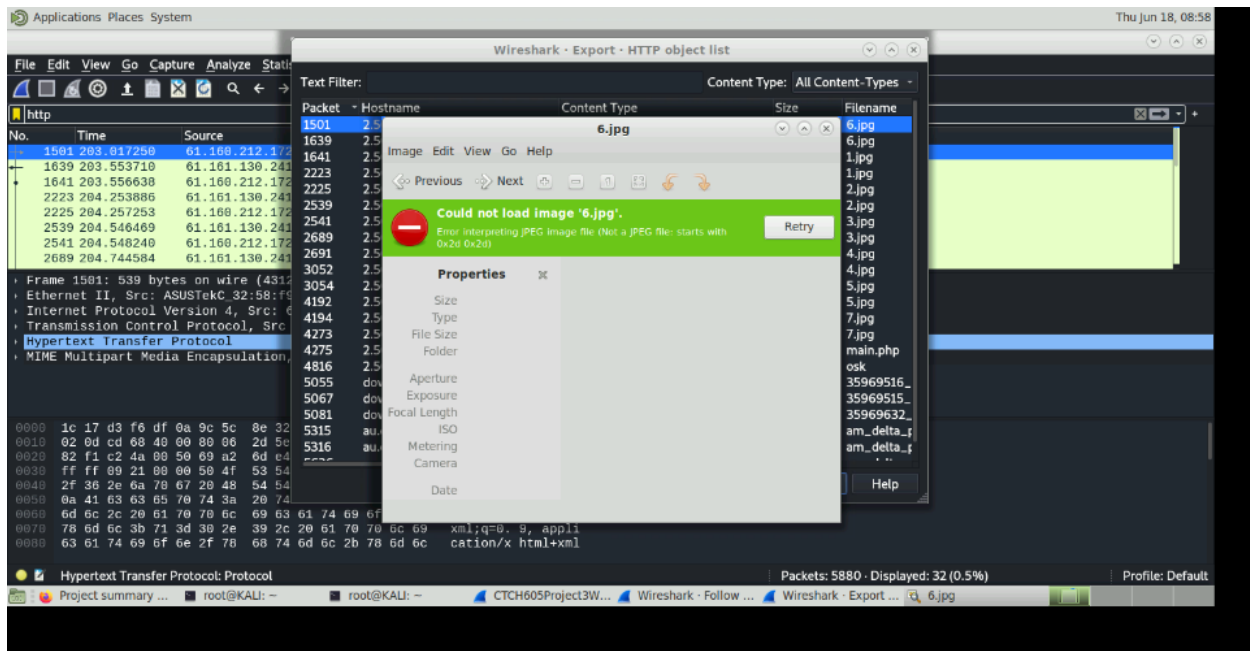


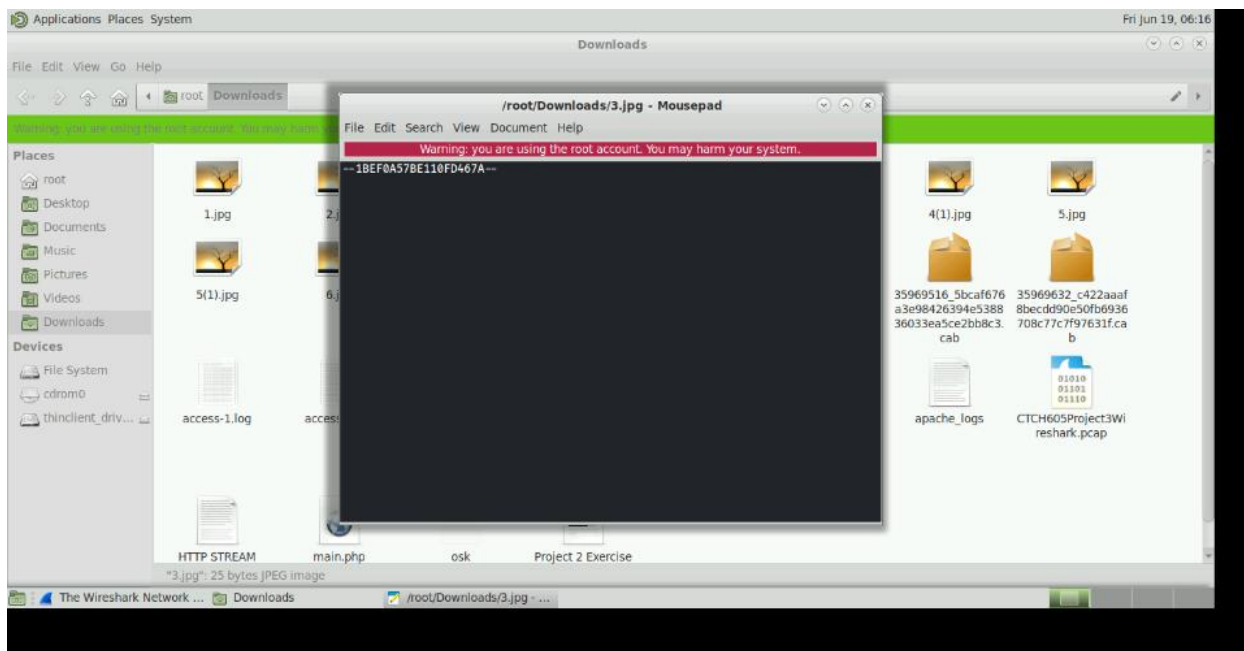
Step 9 - Wireshark Packet Capture Analysis

Action: Using Wireshark, I analyzed the provided packet capture file and filtered traffic using HTTP protocols.

Result





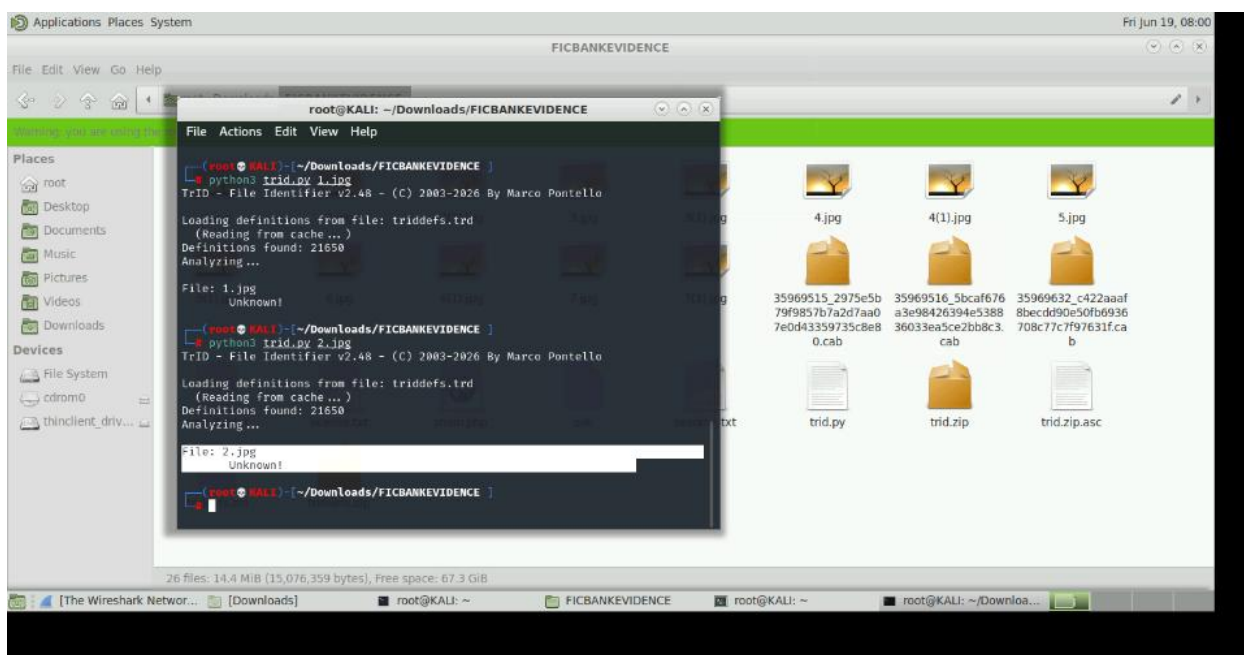
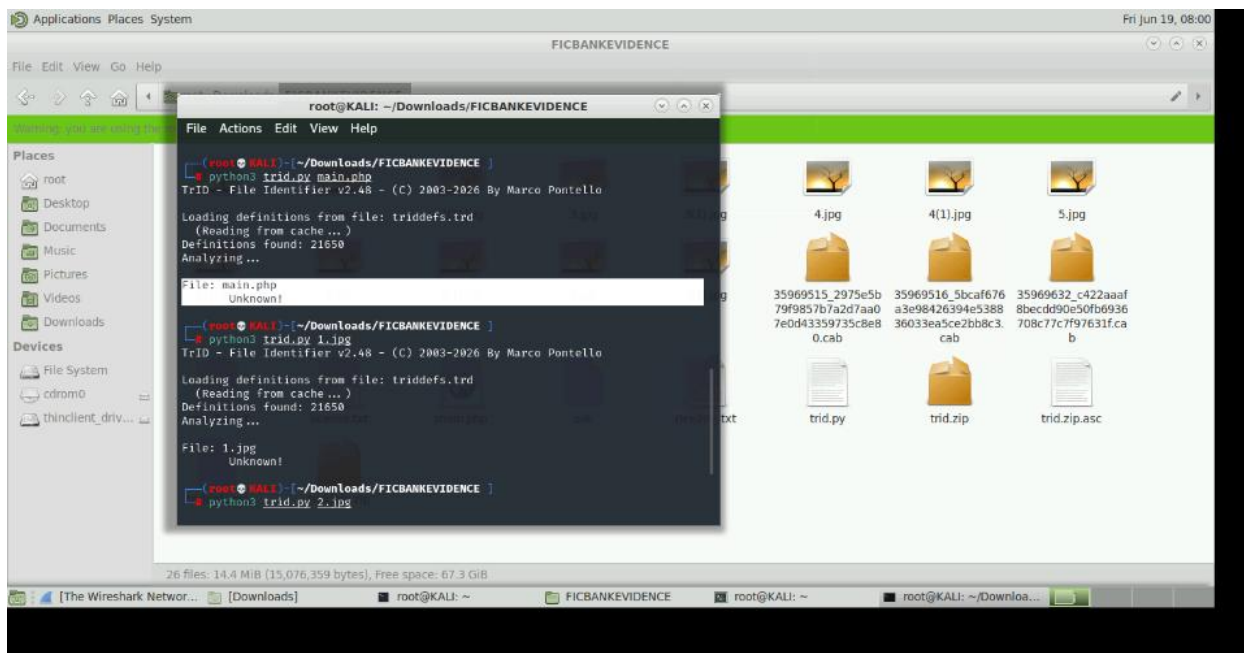


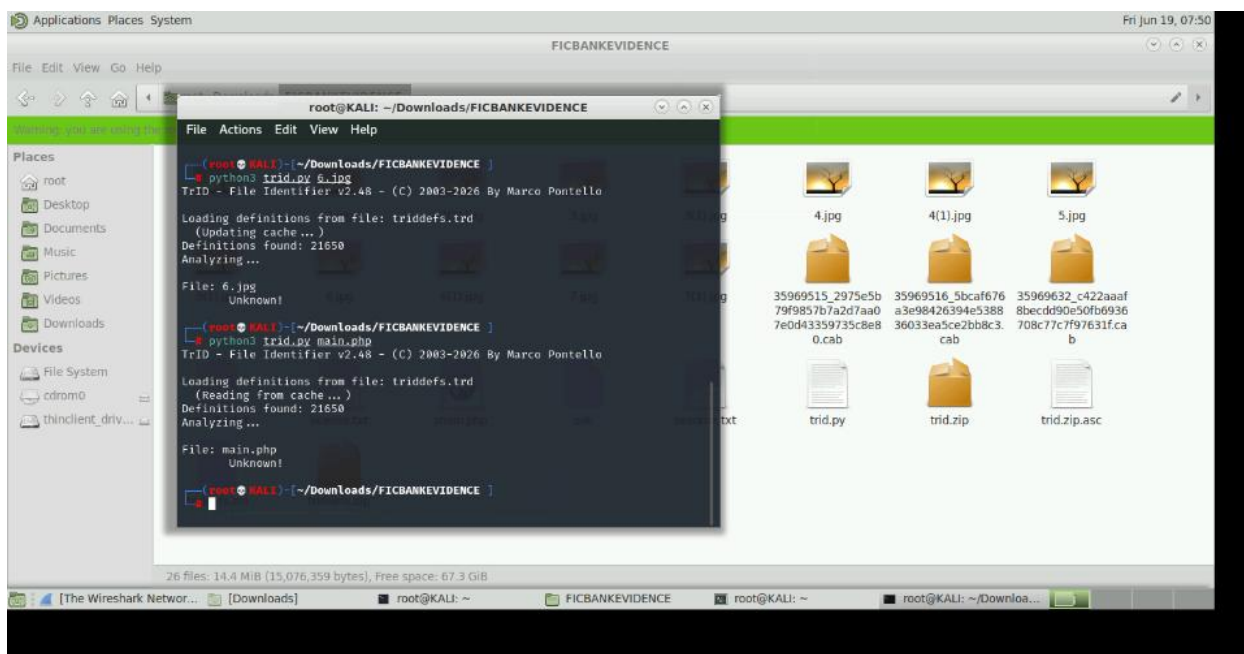
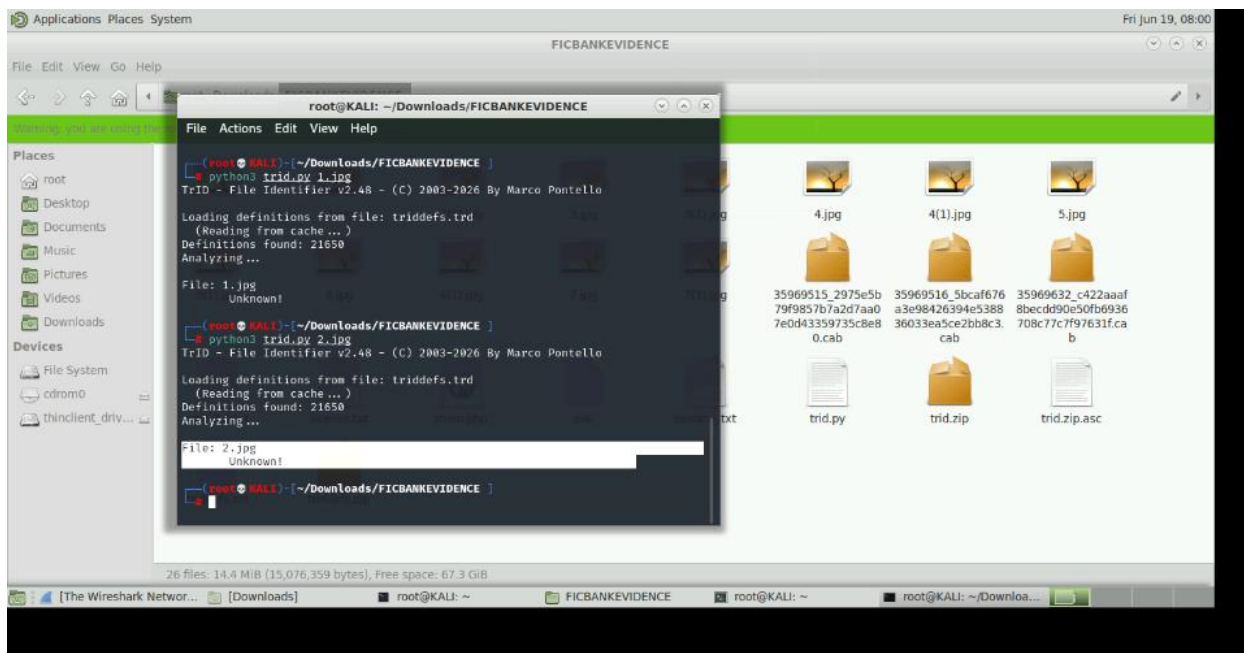
Analysis: When reviewing the exported HTTP objects, I discovered that several files with .jpg extensions could not be interpreted as valid JPEG images. For instance, 6.jpg, 1.jpg and 3.jpg displayed that images could not be loaded. This finding suggests that the files may have been disguised or improperly reconstructed. Additionally, the file main.php appeared suspicious because PHP files are commonly used for web shells and malicious scripts.

Step 10 - TrID File Identification Analysis

Action: TrID was used to determine the true file types of the reconstructed files extracted from the packet capture.

Result





Analysis: The files 1.jpg, 2.jpg, 6.jpg, 7.jpg and main.php were analyzed against more than 21,650 file type definitions. TrID was unable to identify either file and returned an "Unknown" result. These findings were significant because the files could not be validated as legitimate JPEG images or PHP scripts despite their file extensions. The results support previous observations from Wireshark, which indicated that the files did not contain valid image data and appeared to contain multipart/form-data upload information. The inability to identify the files suggests that they may have been incomplete, corrupted, or intentionally disguised, making them potential Indicators of Compromise (IoCs).

Step 11 - Incident Correlation and Indicators of Compromise

The investigation identified several potential Indicators of Compromise (IoCs), including suspicious HTTP POST requests, communications with external host 2.56.57.108, external IP address 95.213.177.126, multipart/form-data file uploads, and the transfer of files disguised as JPEG images. Additionally, a file named main.php and several files classified as unknown by TrID raised concerns about possible unauthorized file upload activity.

Correlating the packet capture, file analysis results, and web server logs increased confidence in the findings and helped establish a timeline of events. The evidence suggests that external systems were interacting with the web application and may have been attempting to upload or transfer suspicious files. While the investigation did not conclusively confirm a successful compromise, the identified IoCs indicate potentially malicious activity that warrants further monitoring, investigation, and remediation.

5. Recommended remediation

Perimeter Security

Recommend next-generation firewalls, IDS/IPS, secure VPN access, and least-privilege firewall rules to reduce the attack surface and prevent unauthorized access.

Network Segmentation

Separate servers, workstations, backup systems, and POS devices into dedicated VLANs with ACLs controlling communication.

Identity and Access Management

Implement MFA, RBAC, strong password policies, account lockout policies, and privileged account monitoring.

DNS and Exchange Security

Enable DNS logging, DNSSEC where appropriate, secure zone transfers, anti-phishing protection, TLS encryption, and MFA for Exchange administrators.

Endpoint Protection

Deploy EDR, antivirus, application allowlisting, disk encryption, USB restrictions, and automated patch management.

Backup and Recovery

Encrypt backups, maintain offline or immutable copies, regularly test recovery procedures, and update disaster recovery documentation.

Vulnerability Management

Conduct authenticated Nessus scans, prioritize remediation based on risk, verify fixes through rescanning, and maintain an ongoing patch management program.

Centralized Monitoring

Deploy Microsoft Sentinel or Splunk, forward logs from all critical systems, configure alert rules, and regularly review security events.

6. Conclusion

The assessment identified both security vulnerabilities and indicators of potentially malicious activity within the FICBANK environment. Vulnerability assessment activities revealed weaknesses that could increase the organization's exposure to attack, while forensic analysis provided evidence of suspicious network communications, file upload activity, and unidentified files transferred through the web application. Correlation of packet capture data, web server logs, and file analysis results identified several Indicators of Compromise, including suspicious HTTP POST requests, external host communications, and unknown file types. These findings emphasize the importance of maintaining a layered security strategy that includes vulnerability management, continuous monitoring, centralized logging, and incident response preparedness. The technical security controls recommended in this assessment provide FICBANK with a layered defense strategy that addresses the vulnerabilities and monitoring gaps identified throughout the engagement. By implementing these recommendations and validating their effectiveness through continuous monitoring, vulnerability assessments, and periodic testing, FICBANK can significantly improve its ability to prevent, detect, respond to, and recover from cybersecurity threats.